Untrusted input boundaries

Learn to understand, design, build, test and explain AI systems responsibly.

Project: Grounded Learning Service

THE CONNECTED WEEK

One complete untrusted-input boundary record.

Keep exact grammar, normalization policy, trusted scope, lookup events, unchanged data and limited claims together.

Keep one habit: Recall → W1–W3/W5 → independent C0 explanation → project input boundary → delayed return.

MAIN LESSON · SECTION 1

Recall · Retrieve before notes

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Try the recall before opening notes. Then use a different colour or a labelled second line to correct your explanation.

- Without opening the old lesson, explain one key idea from External side effects and recovery. Give an example and a mistake that the idea helps you avoid.

- Without opening the old lesson, explain one key idea from Approval gates and idempotency. Give an example and a mistake that the idea helps you avoid.

- Without opening the old lesson, explain one key idea from Logs traces and privacy. Give an example and a mistake that the idea helps you avoid.

- Use this reference for the original W1–W3 and W5 exercises. The separately named independent case supplies its own changed facts; use those facts for that attempt before feedback.

- **Untrusted input** must be treated according to a contract before reaching code, queries or tools. Data that resembles instructions does not acquire execution authority.

- For the toy lookup accept room IDs matching one ASCII uppercase letter plus one ASCII digit, with no trimming. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.

External side effects and recovery

> **My remembered idea, example and correction**

Approval gates and idempotency

> **My remembered idea, example and correction**

Logs traces and privacy

> **My remembered idea, example and correction**
>
> | |
> |---|
> | |
> | |
> | |
> | |

Lesson reference for workbook practice

MAIN LESSON · SECTION 5

W1 · Explain the current example

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Main input is exactly a Python string matching the entire ASCII pattern [A-Z][0-9], with no trimming, case change or coercion. A1 passes shape; delete_all() fails and is never executed. Explicit local extension: trusted scope allows A1 and D4; records provide A1/capacity 12/source ROOM-A1 and an unauthorized B2 record. Only A1/D4 reach lookup; B2 denies before lookup; D4 is missing so reviews.

  Source remains unchanged and only checked response fields are emitted. Main a1, extra characters, trailing whitespace/newline, fullwidth characters, non-ASCII digits and None fail exact shape. Separate picture uses [a-z][0-9]: h3 passes, H3/h30/trailing-space input fail, z0 passes shape but grants no authority. A format pass does not establish resource permission, existence or truth.

  Diagnostic evidence must remain policy-compliant. No input is run as code, SQL, shell or model instruction, and no real authentication or universal injection protection is demonstrated.

- Explain the weekly **mechanism** in your own words. Use the worked scenario to name its **input**, decision rule and **output**.

> **My reasoning and evidence**

MAIN LESSON · SECTION 6

W2 · Trace the calculation

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Main input is exactly a Python string matching the entire ASCII pattern [A-Z][0-9], with no trimming, case change or coercion. A1 passes shape; delete_all() fails and is never executed. Explicit local extension: trusted scope allows A1 and D4; records provide A1/capacity 12/source ROOM-A1 and an unauthorized B2 record. Only A1/D4 reach lookup; B2 denies before lookup; D4 is missing so reviews.

  Source remains unchanged and only checked response fields are emitted. Main a1, extra characters, trailing whitespace/newline, fullwidth characters, non-ASCII digits and None fail exact shape. Separate picture uses [a-z][0-9]: h3 passes, H3/h30/trailing-space input fail, z0 passes shape but grants no authority. A format pass does not establish resource permission, existence or truth.

  Diagnostic evidence must remain policy-compliant. No input is run as code, SQL, shell or model instruction, and no real authentication or universal injection protection is demonstrated.

- **Input**s A1 and delete_all() are supplied to room lookup. Show the intermediate steps and give the conclusion with its scope.

> **My reasoning and evidence**

MAIN LESSON · SECTION 7

W3 · Repair a misconception

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Main input is exactly a Python string matching the entire ASCII pattern [A-Z][0-9], with no trimming, case change or coercion. A1 passes shape; delete_all() fails and is never executed. Explicit local extension: trusted scope allows A1 and D4; records provide A1/capacity 12/source ROOM-A1 and an unauthorized B2 record. Only A1/D4 reach lookup; B2 denies before lookup; D4 is missing so reviews.

  Source remains unchanged and only checked response fields are emitted. Main a1, extra characters, trailing whitespace/newline, fullwidth characters, non-ASCII digits and None fail exact shape. Separate picture uses [a-z][0-9]: h3 passes, H3/h30/trailing-space input fail, z0 passes shape but grants no authority. A format pass does not establish resource permission, existence or truth.

  Diagnostic evidence must remain policy-compliant. No input is run as code, SQL, shell or model instruction, and no real authentication or universal injection protection is demonstrated.

- A report omits this qualification: A format check does not grant resource access; authorisation follows separately. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

My reasoning and evidence

MAIN LESSON · SECTION 9

W5 · Explain the limitation

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Main input is exactly a Python string matching the entire ASCII pattern [A-Z][0-9], with no trimming, case change or coercion. A1 passes shape; delete_all() fails and is never executed. Explicit local extension: trusted scope allows A1 and D4; records provide A1/capacity 12/source ROOM-A1 and an unauthorized B2 record. Only A1/D4 reach lookup; B2 denies before lookup; D4 is missing so reviews.

  Source remains unchanged and only checked response fields are emitted. Main a1, extra characters, trailing whitespace/newline, fullwidth characters, non-ASCII digits and None fail exact shape. Separate picture uses [a-z][0-9]: h3 passes, H3/h30/trailing-space input fail, z0 passes shape but grants no authority. A format pass does not establish resource permission, existence or truth.

  Diagnostic evidence must remain policy-compliant. No input is run as code, SQL, shell or model instruction, and no real authentication or universal injection protection is demonstrated.

- For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison.

  Do not reuse W4 as a new final test after receiving feedback.

> **My reasoning and evidence**

MAIN LESSON · SECTION 4

Try alone · Selected transfer

> Keep this task's inputs,rule and response together.

Complete task and evidence

- **Input** format is exactly one ASCII uppercase letter followed by one digit, with no trimming. Evaluate C0, c0, C00, "C0 ", and None. Does a valid format grant access?

- Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

Independent case: Changed independent case

My independent explanation, trace and limits

MAIN LESSON · SECTION 10

Project · Keep the service evidence

> Preserve the contract, inputs, observed outcomes and limits.

Complete task and evidence

- Add a labelled **untrusted input** boundaries **evidence** sheet to Grounded Learning Service. Show how you can explain the **mechanism** and terminology of **untrusted input** boundaries.

  Use the supplied fictional case and keep its **input**s, intermediate steps, calculation or **prediction**, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

My project change, supporting evidence and remaining limit

MAIN LESSON · SECTION 11

Feedback · Repair and return

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Revisit this idea with your teacher after a delay. Familiarity is different from explaining and using it on a changed case.

Evidence	My record
Worked alone / hint / model	
First step I repaired and why	
New case checked later; date and result	
What I can now explain without notes	
One remaining question	

Reference bank and extra practice

Choose the reference that helps your next step.

▼ **Reference · Supported W2 record**

REFERENCE · SECTION 2

Reference · Supported W2 record

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Use W2: Trace the worked case for **Untrusted input** boundaries. Record the answer once; the lesson and workbook refer to the same attempt.

Given inputs	Procedure I chose	Middle steps	Result and check

> **The step I completed without help, and the hint I needed**

▼ Extra practice · Individual reasoning check

REFERENCE · SECTION 3

Extra practice · Individual reasoning check

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Use the worked case for **Untrusted input** boundaries. Proposed explanation: "The worked result establishes every future case". Decide whether this explanation is supported.

  Point to the step or supplied fact that decides; explain your repair if needed.

> **My explanation before partner discussion**

▼ Reference · Earlier W4 response copy

REFERENCE · SECTION 8

Reference · Earlier W4 response copy

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Classify B2, b2, B22 and B2; DROP under the exact format.

> **My reasoning and evidence**

▼ **Extra practice · Pictured case**

REFERENCE · SECTION 12

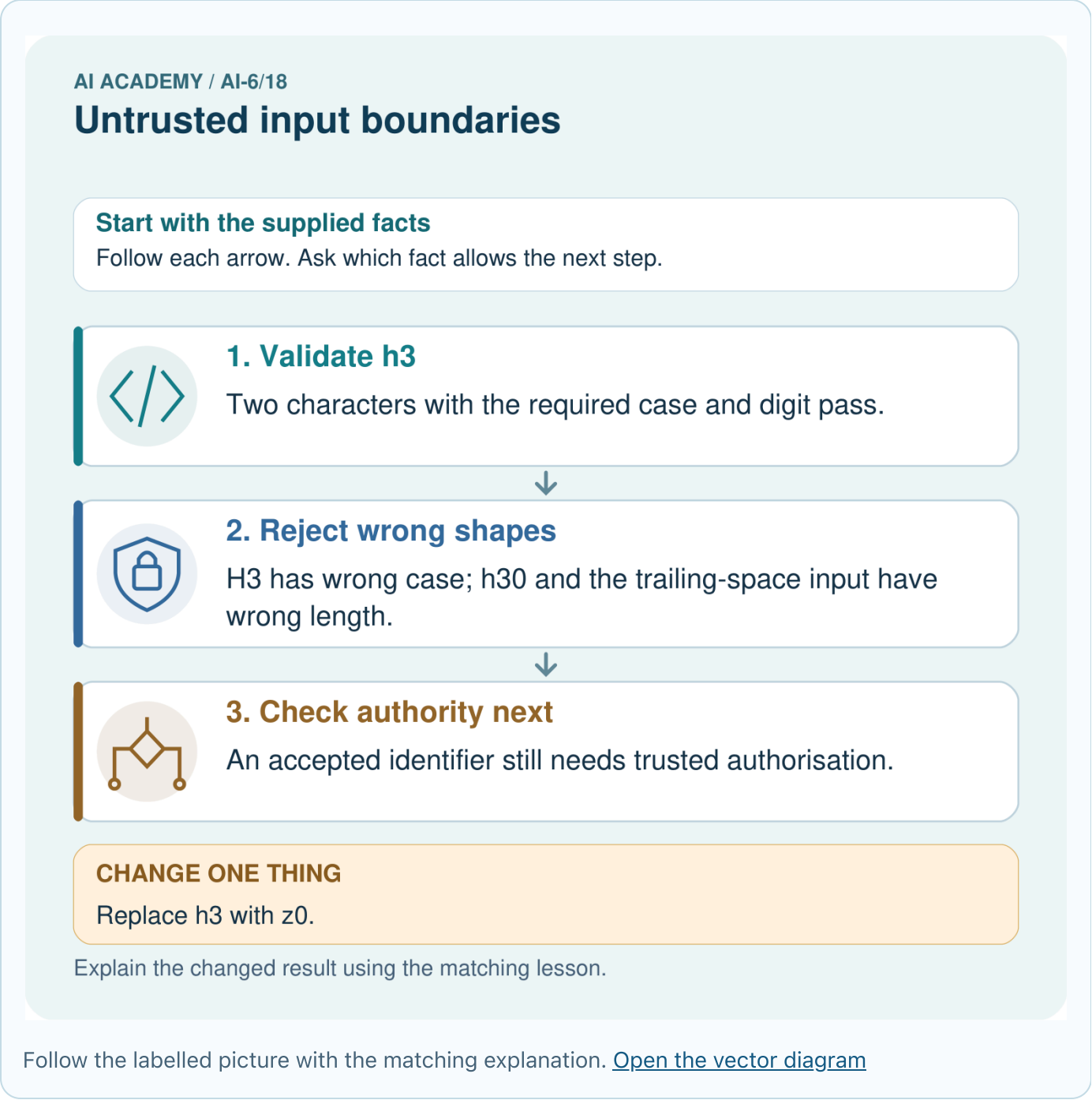
Extra practice · Pictured case

> Keep this task’s inputs,rule and response together.

Complete task and evidence

- Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one ASCII digit, with no trimming.
- **Input**s h3, H3, h30 and "h3 ". Shape acceptance never grants access by itself.
- Classify h3, H3, h30 and the trailing-space **input** by the stated shape contract. Does a valid z0 grant record access, and which separate gate still remains?
- Support used: alone / hint / worked example. This record is practice **evidence**.

- Project connection: For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.



Follow the labelled picture with the matching explanation. Open the vector diagram

My picture-based explanation and changed-case prediction

▼ **Reference · Project milestone**

REFERENCE · SECTION 13

Reference · Project milestone

> Keep this task's inputs,rule and response together.

Complete task and evidence

- Project: Grounded Learning Service
- Current milestone: Test changed cases. Keep normal, boundary and failure cases; compare expected and observed results.
- For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

Evidence to keep	My record
This week's input and deciding step	
Prediction and actual result (or labelled paper trace)	
One change since the previous checkpoint and why	

Evidence to keep	My record
One error or limit and the next test	

> **Explain what this week adds to your project. Reuse last week's record rather than starting again.**

▼ **Extra practice · Predict,check and repair**

REFERENCE · SECTION 14

Extra practice · Predict,check and repair

> Keep supported feedback separate from the independent case.

First supported question and optional hint

- Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one ASCII digit, with no trimming.
- Which labelled step matches this detail? An accepted identifier still needs trusted authorisation.
- 1. Reject wrong shapes
- 2. Check authority next

- 3. Validate h3

- Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

Practice 1: explain the deciding evidence

> **My selected conclusion, deciding fact and explanation**
>
> ---
>
> ---
>
> ---
>
> ---

▼ **Check after the first attempt**

After your attempt, compare with the supported explanation: Check authority next An accepted identifier still needs trusted authorisation. **Input** shape and permission answer different questions.

Silently normalising these **input**s would change the stated contract.

Changed-case question and optional hint

- Changed-case practice: Replace h3 with z0. Which conclusion is supported by the supplied facts?

- 1. We can decide the result without examining the changed **input** or the procedure.

- 2. The shape passes; resource access is still undecided.

- 3. This one example guarantees correct results for every future **input**.

- Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

Practice 2: explain the deciding evidence

My selected conclusion, deciding fact and explanation

▼ **Check after the changed attempt**

After your attempt, compare with the supported explanation: The shape passes; resource access is still undecided. Structure contains no **evidence** of ownership or user permission.

Repair and retain the record

Review External side effects and recovery (ai-6/17). Goal: Explain the **mechanism** and terminology of external side effects and recovery. Short practice: Distinguish a missing printer acknowledgement from confirmed failure.

What should happen if J6 is complete, and what **evidence** changes when J6 is reliably reported absent?. Return to this week and explain what you changed.

Review Approval gates and idempotency (ai-6/15). Goal: Explain the **mechanism** and terminology of approval gates and idempotency. Short practice: Trace the two deliveries of approved K9.

How many reservations should occur, and why can a new K10 for desk 5 not borrow K9's approval?. Return to this week and explain what you changed.

Review Logs traces and privacy (ai-6/12). Goal: Explain the **mechanism** and terminology of logs traces and privacy. Short practice: Identify the purpose of R17, C8 and 240 ms in the trace.

Which field is deliberately omitted, and why would logging the whole question violate this design?. Return to this week and explain what you changed.

The browser lab lets you edit the supported Python examples already included in this lesson. Predict first, run, inspect the actual **output** or error, change one **input**, then run again.

Keep code, **prediction**s, actual results and a reasoned revision together. On paper, label your result as a trace rather than an execution.

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run **evidence**. Open the HTML copy to read or print it.

Drafts stay in this browser when storage is available; clear drafts on a shared device.

> **What I repaired, the evidence I kept and the next test**
>
> | | |
> |---|---|
> | | |
> | | |
> | | |
> | | |

▼ **Earlier wording, alternatives and picture transcripts**

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

Repair a missing building block

Predict, run and debug

Keep your completed work

▼ **Reference · Six-picture response sheets**

REFERENCE · SECTION 15

Reference · Six-picture response sheets

> Choose the picture that helps explain the current step.

01. Untrusted input boundaries: the case

AI ACADEMY / AI-6/18 · 01 · LOOK AT THE FACTS

Untrusted input boundaries: the case

The situation

Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one ASCII digit, with no trimming.

Supplied evidence

Inputs h3, H3, h30 and "h3 ". Shape acceptance never grants access by itself.

Explain untrusted input boundaries using the deciding step in this fictional service.

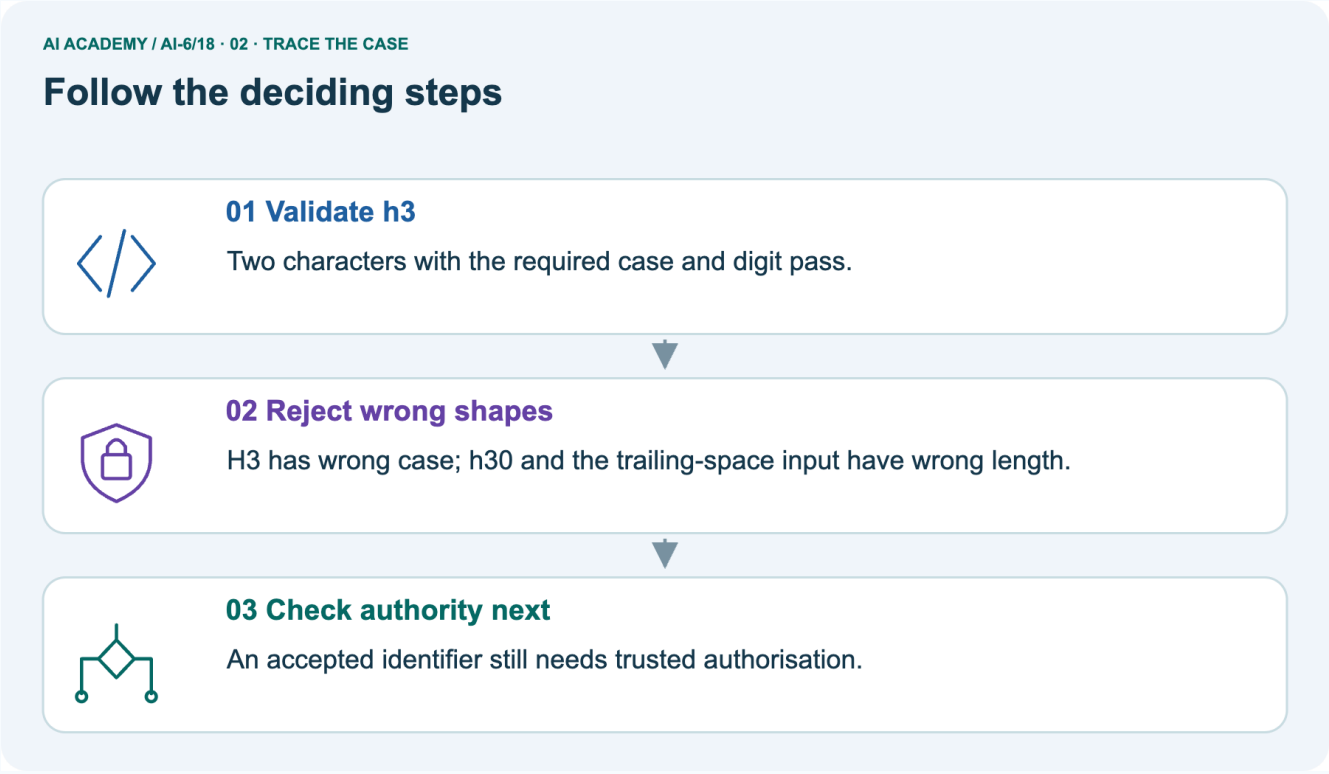
Follow the labelled picture with the matching explanation. Open the vector diagram

Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one ASCII digit, with no trimming. Supplied facts: **Input**s h3, H3, h30 and "h3 ". Shape acceptance never grants access by itself.

Point to the given fact that matters most. Explain why it matters.

My picture explanation, deciding evidence and one limit

02. Follow the deciding steps



Follow the labelled picture with the matching explanation. Open the vector diagram

Validate h3: Two characters with the required case and digit pass. → Reject wrong shapes: H3 has wrong case; h30 and the trailing-space **input** have wrong length. → Check authority next: An accepted identifier still needs trusted authorisation.

Point to each numbered stage and explain which recorded **input** it uses.

My picture explanation, deciding evidence and one limit

03. Untrusted input boundaries — evidence trace

AI ACADEMY / AI-6/18 · 03 · INSPECT THE LESSON MODEL

Untrusted input boundaries — evidence trace

Input and scope	Check or calculation	Conclusion and limit
Inputs A1 and delete_all() are supplied to room lookup.	For the toy lookup accept room IDs matching one ASCII uppercase letter plus one ASCII digit, with no trimming. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.	A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

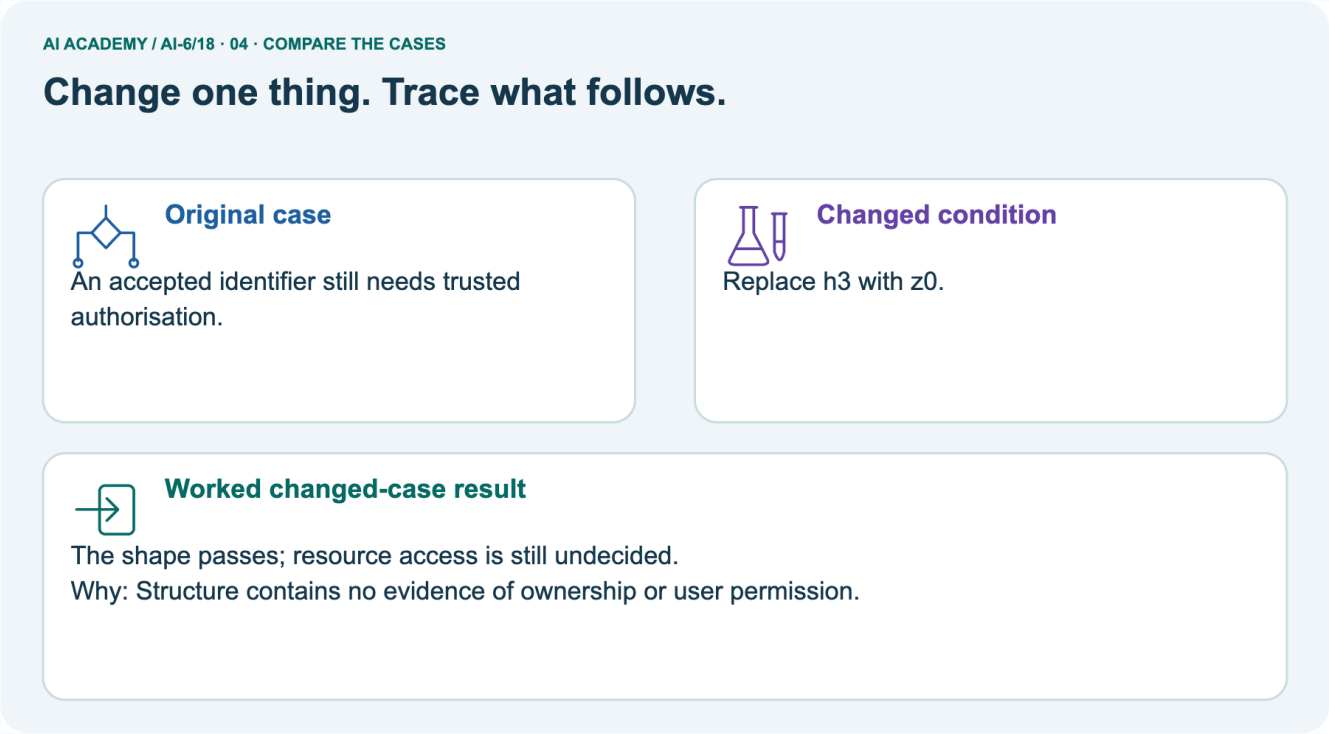
Follow the labelled picture with the matching explanation. Open the vector diagram

Untrusted input boundaries — **evidence** trace. **Input**s A1 and delete_all() are supplied to room lookup. | For the toy lookup accept room IDs matching one ASCII uppercase letter plus one ASCII digit, with no trimming. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters. | A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

Read the labels and values. Explain the relationship the model shows.

My picture explanation, deciding evidence and one limit

04. Change one thing. Trace what follows.



Follow the labelled picture with the matching explanation. Open the vector diagram

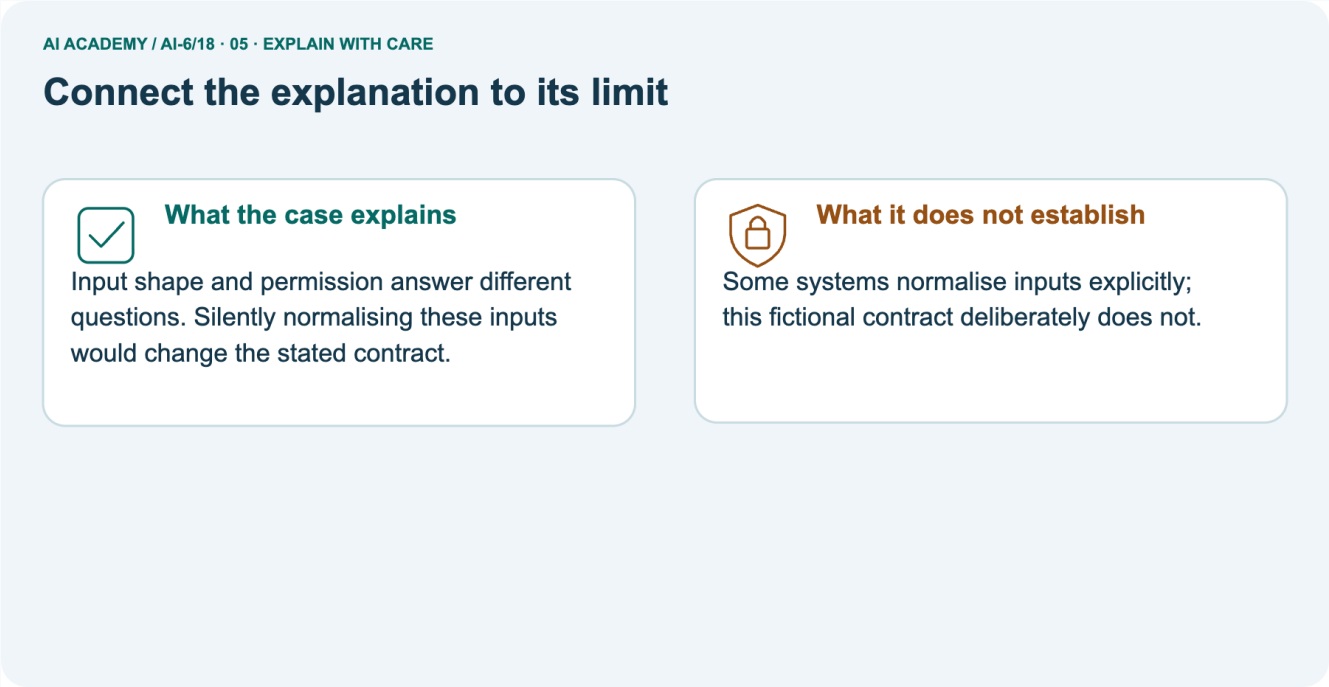
Original case: An accepted identifier still needs trusted authorisation. Changed condition: Replace h3 with z0. Expected result: The shape passes; resource access is still undecided.

Reason: Structure contains no **evidence** of ownership or user permission.

Predict before checking the worked changed-case result. Name what changed and what the supplied facts allow you to conclude.

My picture explanation, deciding evidence and one limit

05. Connect the explanation to its limit



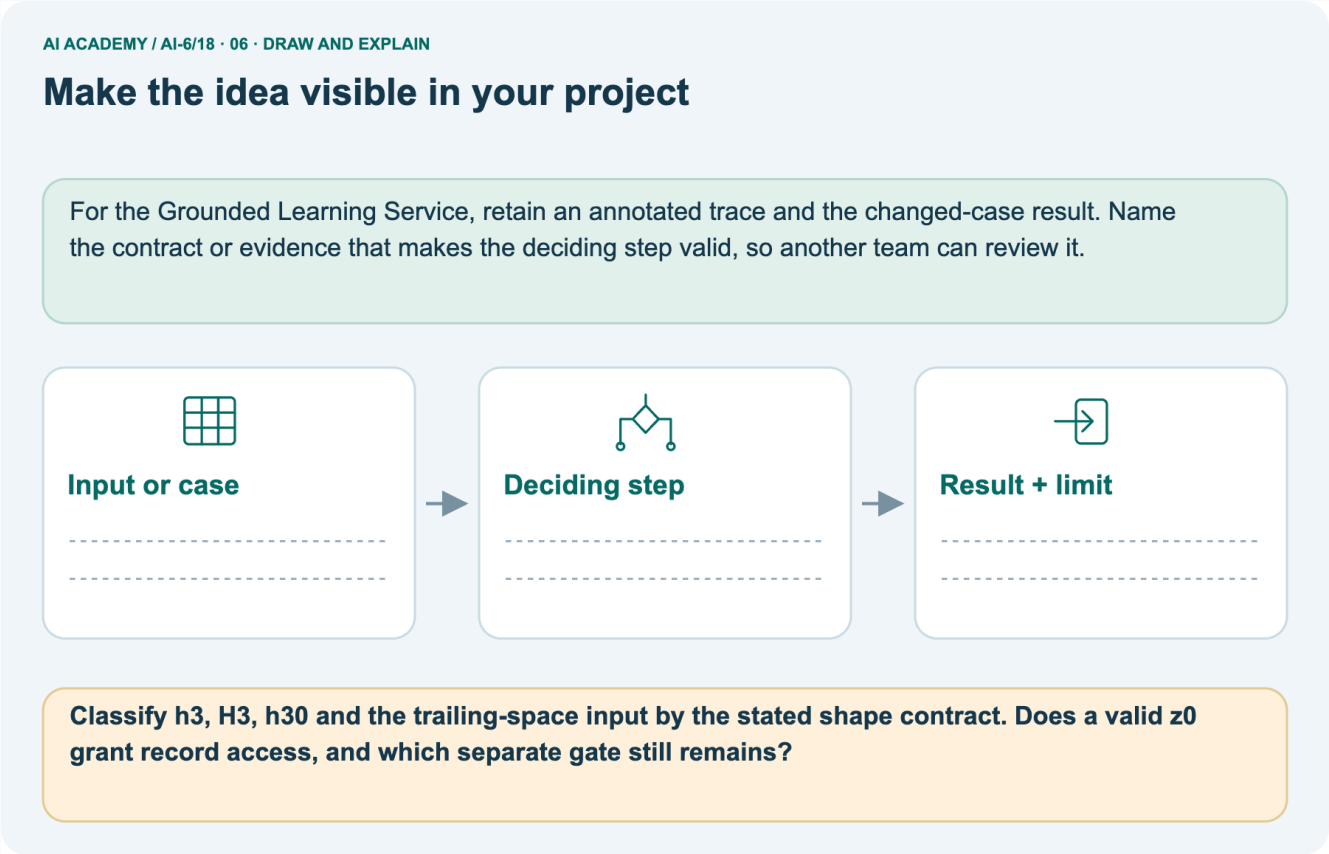
Follow the labelled picture with the matching explanation. Open the vector diagram

Input shape and permission answer different questions. Silently normalising these **input**s would change the stated contract. Limit: Some systems normalise **input**s explicitly; this fictional contract deliberately does not.

Explain the case, then point to a limit on the claim.

My picture explanation, deciding evidence and one limit

06. Make the idea visible in your project



Follow the labelled picture with the matching explanation. Open the vector diagram

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

Draw your **input**, deciding step, result and limit. Supported question: Classify h3, H3, h30 and the trailing-space **input** by the stated shape contract. Does a valid z0 grant record access, and which separate gate still remains?

Draw your project trace and justify the deciding step using **evidence**.

My picture explanation, deciding evidence and one limit

▼ Earlier wording, alternatives and picture transcripts

01. Untrusted input boundaries: the case

02. Follow the deciding steps

03. Untrusted input boundaries — evidence trace

04. Change one thing. Trace what follows.

05. Connect the explanation to its limit

06. Make the idea visible in your project

▼ Optional interactive practice and completed work

Save or print your responses for your portfolio. Progress and drafts on the hosted website stay in the current browser. Use only fictional or teacher-approved data.